

Architecture & Security Assessment

Version 3.0 — July 2026

Prepared by: Engineering & Security Review

Classification: CONFIDENTIAL — Internal Use Only

9 / 13

Code Risks Fixed

2

Follow-ups Queued

7

Vendor Items Open

Table of Contents

1. Executive Summary	2
2. Platform Architecture Overview	2
3. Authentication & Role Model	3
4. Data Storage Architecture	3
5. External Integrations	4
6. Security Findings & Remediation Status	4
7. Remaining Risk Register	6
8. Remediation Roadmap	7
9. Recommendations	8

1 Executive Summary

Koheez.ai is a HIPAA-regulated clinical decision support platform serving AHF pharmacy teams across multiple regions. This document provides a current-state assessment of the platform architecture, authentication model, data storage, external integrations, and security posture as of July 2026 following the completion of Task #137 (Security Hardening — Code-Only Fixes).

A governance audit conducted in July 2026 identified 20 risk items across Critical, High, Medium, and Low severity bands. Of these, 13 were addressable through code changes alone. Task #137 resolved 9 of those 13 items. The remaining 4 code-addressable items are tracked in follow-up tasks (#138 and #139). The remaining 7 items require external vendor coordination, infrastructure provisioning, or contractual agreements (BAAs) and are catalogued in the Remaining Risk Register.

Category	Count	Status
Code risks resolved (Task #137)	9	FIXED — merged to production
Code risks deferred to follow-up tasks	4	IN PROGRESS — Task #138, #139
Vendor / infrastructure risks open	7	OPEN — requires external action
Total risks identified	20	

2 Platform Architecture Overview

Koheez.ai follows a monorepo full-stack pattern with a React/TypeScript frontend served by Vite and an Express.js/TypeScript backend. Both are deployed on a single Node.js process via Vite's development server proxy in development, and as a compiled Express server in production (Replit/Aptible).

Frontend

Framework:	React 18 + TypeScript via Vite
Routing:	Wouter (client-side SPA)
UI Components:	Shadcn/ui (Radix UI) + Tailwind CSS
State / Data:	TanStack Query v5 for server state; React hooks for UI state
Forms:	react-hook-form + Zod resolvers
Offline-first sync:	localStorage !" server via /api/client-store (debounced push + hydrate)
Teams embedding:	Microsoft Teams SDK; SameSite=None secure cookies; silent SSO via Azure AD JWKS token validation

Backend

Runtime:	Node.js 20 + TypeScript (tsx in dev, compiled for prod)
Framework:	Express.js — single registerRoutes() function, ~2,800 LOC
ORM:	Drizzle ORM with Neon serverless PostgreSQL driver
Session:	express-session + connect-pg-simple (PostgreSQL-backed sessions)
Validation:	Zod schemas shared between frontend and backend via @shared/schema
Authentication:	Session-based; bcrypt password hashing (cost 10) via bcryptjs
Scheduling:	node-cron for daily outreach (09:00) and ADP sync (02:00)

3 Authentication & Role Model

The platform uses a hierarchical 5-tier role model. Role is determined at login from a static user registry (DEMO_USERS) extended by an in-memory user store. A database-backed user table is planned in Task #138.

Role	Scope	Key Permissions
CPO (Chief Pharmacy Officer)	National	Full access to all stores, audit log, user admin, national dashboard, category reports
RPD (Regional Pharmacy Director)	Regional	Regional dashboard, schedule approvals, task tracker, QA audit oversight, store performance
Pharmacy Director (PD)	Store	Store scheduling (submit), CQI meeting editing, ACHC workbook, QA audit, WA inspection, fax log, inventory management
Staff Pharmacist / Pharmacist	Store	HIV/PrEP Assessor, task completion, CQI signing, inventory adjustments, controlled inventory read/write
Pharmacy Technician	Store	Task completion, controlled inventory read-only, CQI signing

Session Configuration

Cookie flags:	HttpOnly, Secure (prod), SameSite=None (Teams iframe compat)
Store:	PostgreSQL via connect-pg-simple — sessions survive redeloys
Secret:	SESSION_SECRET env var required at startup; server throws if absent in production
Token validation:	Microsoft Entra ID JWKS endpoint for Teams SSO silent login

Password Policy (as of Task #137)

- All passwords hashed with bcrypt, cost factor 10 (bcryptjs — pure JS, no native build required)
- Login uses bcrypt.compareSync; plaintext comparison removed
- Signup enforces minimum 12 characters, at least one letter and one number (Zod schema)
- Shared 'AHF1' credential is hashed at startup — per-user unique passwords tracked in Task #138

4 Data Storage Architecture

Storage is split across three layers based on consistency requirements and access frequency:

PostgreSQL (Neon Serverless) — Primary Persistent Store

All shared, multi-user records that must survive restarts and be consistent across devices are stored in PostgreSQL. Tables use a natural-key + JSONB pattern for schema flexibility.

Table	Contents
session	Express session store (auto-created by connect-pg-simple)
cqi_meetings	Quarterly CQI-QRE meeting records and digital attendance signatures
audit_logs	HIPAA access audit log — immutable, append-only, capped at 10,000 entries in mem + PostgreSQL
retention_patients	Patient retention records for outreach sequencing
pharmacy_hours	Store business hours and holiday closures
staff_schedule_defaults + entries	Team scheduling data (default shifts + per-date overrides)

schedule_submissions	P D !' R P D s c h e d u l e a p p r o v a l w o r k f l o w s t a t e
notifications	In-app notification queue (schedule approvals, QA failures)
qa_workbooks / qa_evidence / qa_tasks	Annual QA Audit Readiness workbooks, file evidence metadata, and follow-up tasks
client_store	Server-side backing for browser localStorage (18 allowlisted koheez_* keys, scoped per site)
adp_worker_mappings / adp_sync_status / adp_sync_history	ADP Workforce Now worker mappings and sync history
wa_inspection_archives	WA State Self-Inspection annual archives

Browser localStorage — High-Frequency UI State

Synchronous writes used by existing feature modules (task completions, inventory, ACHC docs). Synced to client_store in PostgreSQL on every write (debounced 150–800ms) and hydrated on login. PHI key (koheez_assessments) is cleared on logout.

File System (.local/) — Dev-Only Fallback

QA audit state, audit log, and CQI meeting JSON files persist across dev restarts. Production relies entirely on PostgreSQL; file-backed storage is a development convenience only.

5 External Integrations

Service	Protocol	Purpose
OpenAI GPT-4o	HTTPS / REST	AI-generated clinical summaries, consultation questions, schedule assistant
Liverpool HIV DDI API	HTTPS / REST	Authoritative drug-drug interaction data and severity ratings
NIH RxTerms (Clinical Tables)	HTTPS / REST	Medication autocomplete for assessment form
Microsoft Entra ID (Azure AD)	HTTPS / JWKS	Teams SSO silent token validation for iframe embedding
Microsoft Graph API (Outlook)	HTTPS / OAuth2	Email delivery for automated 4-day patient outreach sequence
Salesforce API	HTTPS / OAuth2	Logging retention activities as Tasks/Activities in Salesforce CRM
Clerkchat API	HTTPS / REST	SMS delivery for automated patient outreach sequence
ADP Workforce Now	HTTPS / mTLS cert	Worker time-off import for scheduling (daily cron, 02:00)
JotForm API	HTTPS / REST (webhook)	Patient Service Agreement submission!
sFax API	HTTPS / REST	Auto-fax JotForm PDF to McKesson ICQ queue
Neon PostgreSQL	TLS / libpq	Primary database (serverless connection pooling)

6 Security Findings & Remediation Status

The July 2026 governance audit identified 20 security risk items. The table below covers all 13 code-addressable findings with their current remediation status. Vendor-dependent items are listed separately in Section 7.

#	Severity	Finding	Status	Resolution / Notes
1	CRITICAL	Plaintext password comparison in login handler	FIXED	bcryptjs installed (cost 10); bcrypt.compareSync replaces === check. Task #137.
2	CRITICAL	Hardcoded SESSION_SECRET fallback ('koheez-dev-secret')	FIXED	Fallback removed. Production throws on startup if SESSION_SECRET env var is absent. Dev gets random ephemeral value. Task #137.
3	HIGH	Shared 'AHF1' credential across all demo users	OPEN	Passwords hashed at startup (Task #137). Per-user unique passwords, mustChangePassword flag, and change-password endpoint tracked in Task #138.
4	HIGH	No CSRF protection on state-mutating API routes	OPEN	Not implemented in Task #137 due to SameSite=None cookie complexity (Teams iframe). csrf-csrf integration planned for Task #138.
5	HIGH	No audit trail for login success / failure events	FIXED	recordAccess('auth.login.success/failure') added to standard login handler. IP and timestamp recorded. Task #137.

6	HIGH	Bulk patient import not audited	FIXED	recordAccess('patient.import') added to /api/retention/import after write. Counts imported/skipped rows. Task #137.
7	HIGH	PHI client-store writes not logged	FIXED	recordAccess('client-store.write.ph') added when koheez_assessments key is written via PUT /api/client-store. Task #137.
8	HIGH	JotForm webhook endpoint unauthenticated	FIXED	X-Webhook-Secret header validated against JOTFORM_WEBHOOK_SECRET env var; mismatched requests rejected 401. Task #137.
9	MEDIUM	PHI left in browser localStorage after logout	FIXED	koheez_assessments cleared via localStorage.removeItem() in logoutMutation.onSuccess before redirect. Task #137.
10	MEDIUM	No password complexity requirements at signup	FIXED	Signup requires min 12 chars + letter + number via Zod schema; returns 400 with descriptive message. Task #137.
11	MEDIUM	No bulk audit log export for compliance review	FIXED	GET /api/audit-log/export (CPO-only) streams full log as RFC 4180 CSV. 'Export CSV' button added to Audit Log page. Task #137.
12	MEDIUM	No database-backed user management (CPO admin UI)	OPEN	Endpoints POST/DELETE /api/admin/users and /app/admin/users CPO page planned in Task #138.
13	LOW	No regression / security-path automated test suite	OPEN	Auth flows, RBAC enforcement, and audit log coverage tracked in Task #139.

7 Remaining Risk Register — Vendor / Infrastructure Items

The following 7 items cannot be resolved through code changes alone. Each requires coordination with an external vendor, a BAA agreement, or infrastructure provisioning. These remain open and are the responsibility of the designated owner.

Severity	Category	Risk	Owner	Action Required
CRITICAL	BAA	OpenAI processes PHI in AI summaries — no BAA in place	CPO + Legal	Execute BAA with OpenAI or migrate to Azure OpenAI HIPAA-eligible tier (Task #75)
CRITICAL	BAA	Clerkchat SMS sends patient contact data — no BAA	CPO + Legal	Execute BAA with Clerkchat or select alternative HIPAA-covered SMS provider
HIGH	OAuth	Outlook OAuth refresh token stored as plaintext env var — not rotated	Microsoft IT	Move to Azure Managed Identity or automate refresh token rotation with secret manager
HIGH	OAuth	Salesforce OAuth credentials hard-coded — no rotation policy	Salesforce Admin	Implement OAuth token rotation; store in secrets manager, not env vars
HIGH	Infra	Dev and prod share same database / session store	DevOps / CPO	Provision separate Neon project for production; update connection string in prod env
MEDIUM	API	JotForm webhook lacks Authorization header support (JotForm limitation)	JotForm / Engineering	Add IP allowlist for JotForm webhook origin or request feature from JotForm
MEDIUM	BAA	sFax transmits fax metadata — BAA status unconfirmed	CPO + Legal	Confirm or execute BAA with sFax for PHI fax transmission

8 Remediation Roadmap

Timeframe	Task	Category	Deliverable
Completed (Jul 2026)	Task #137	Code	9 code-only security hardening items — bcrypt, session secret, audit logging, webhook validation, PHI logout, password complexity, CSV export
30 days	Task #138	Code	Per-user unique passwords with mustChangePassword flag; POST/DELETE /api/admin/users endpoints; /app/admin/users CPO management page; csrf-csrf middleware integration
30 days	Task #139	Testing	Automated regression suite covering auth flows, RBAC enforcement, audit log writes, and PHI data hygiene paths
30 days	Task #75	Infra/Legal	Migrate OpenAI calls to Azure OpenAI HIPAA-eligible endpoint; execute BAA
60 days	—	Legal/Vendor	Execute BAA with Clerkchat (SMS) and confirm BAA status with sFax. Escalate if unable — PHI must not traverse non-BAA systems

60 days	—	Infra	Provision separate production database (Neon project). Update SESSION_SECRET and DATABASE_URL in prod env. Run db:push to apply schema
90 days	—	OAuth/Infra	Implement OAuth token rotation for Outlook and Salesforce using a secrets manager. Remove plaintext tokens from env vars
90 days	—	API	Investigate JotForm IP allowlist or move to authenticated polling model to eliminate unauthenticated webhook surface

9 Recommendations

9.1 Immediate (Complete before next audit cycle)

- Complete Task #138: per-user passwords, CSRF middleware, admin user management UI. These items were in scope for Task #137 but deferred — they close the two remaining HIGH-severity code risks.
- Complete Task #139: regression test suite. Automated tests are the safety net for future changes; without them, security regressions are undetectable until an audit.
- Execute BAA with OpenAI or migrate to Azure OpenAI. Any use of OpenAI with PHI data (clinical notes, patient identifiers in AI prompts) is a HIPAA violation without a BAA. This is the highest-priority vendor action.

9.2 Short-term (30–60 days)

- Provision a separate production database. Sharing a database between dev and prod creates risk of test data contaminating production records and of a developer mistake affecting live patient data.
- Execute BAA with Clerkchat. SMS messages in the outreach sequence include patient contact information; this constitutes PHI in transit. A BAA is required under 45 CFR §164.308(b).
- Confirm sFax BAA status. The McKesson ICQ fax flow transmits patient document PDFs; verify sFax is HIPAA-covered before continuing automated faxing.

9.3 Medium-term (60–90 days)

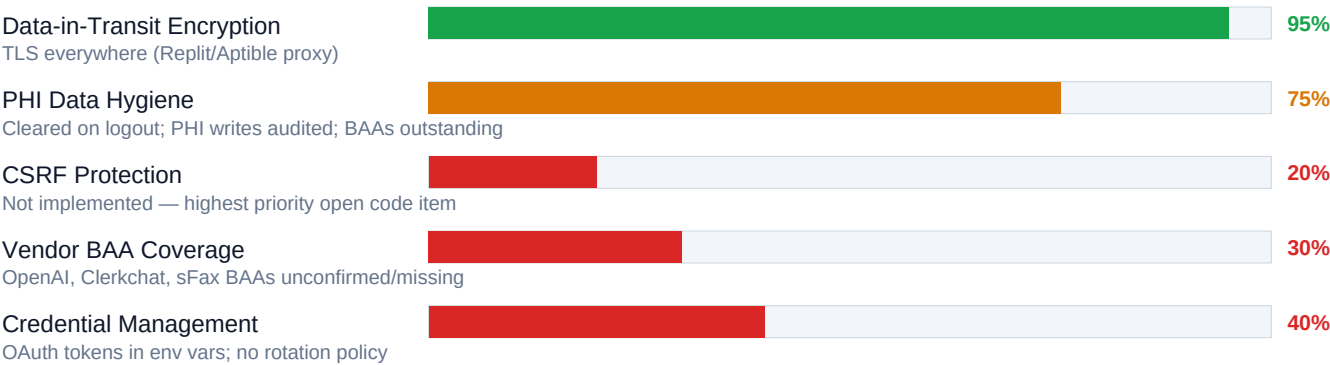
- Implement OAuth token rotation for Outlook and Salesforce. Hard-coded refresh tokens with no expiry or rotation policy are a standing credential leak risk.
- Move all secrets to a secrets manager (AWS Secrets Manager, Azure Key Vault, or similar). The current pattern of storing API keys in environment variables is acceptable short-term but does not support audit trails, rotation policies, or fine-grained access control.
- Add rate limiting on authentication endpoints. The `/api/auth/login` route currently has no brute-force protection. Use `express-rate-limit` to cap attempts per IP (e.g. 10 attempts / 15 minutes).
- Add IP-based allowlisting or signed request verification for the JotForm webhook to replace the current shared-secret approach, which does not rotate automatically.

9.4 Architectural Notes

- The `client_store sync mechanism (localStorage! PostgreSQL)` is a practical bridge but introduces a dual-truth risk. When the server-side backup diverges from the client, the pending marker system re-pushes local values — this is correct behavior but should be monitored. Consider migrating high-value stores (controlled inventory, ACHC docs) to a fully server-authoritative model.
- The `DEMO_USERS` array in `server/routes.ts` mixes application configuration with user credentials. Task #138's database-backed user table will eliminate this anti-pattern and allow credential rotation without a code deployment.
- ADP mTLS integration uses client certificate files on the filesystem. Ensure these certificates are stored in secrets management and are rotated before expiry. Certificate expiry is not currently monitored.
- The session table is auto-created by `connect-pg-simple` and is not tracked in Drizzle schema. Any database migration that drops-and-recreates tables (e.g., via `drizzle-kit push --force`) will destroy all active sessions. Never run interactive `drizzle-kit push` in production.

9.5 Security Posture Summary

Password Storage		85%
bcrypt at cost 10 — good; shared credential still exists		
Session Management		90%
PostgreSQL-backed; SESSION_SECRET enforced		
Access Audit Logging		80%
Login, import, PHI writes logged; CSV export available		



This document is classified CONFIDENTIAL and intended for internal use only. It contains sensitive security information about the Koheez.ai platform architecture. Distribution outside the Engineering and Pharmacy Operations leadership teams requires CPO approval. Findings and scores reflect the state of the system as of July 22, 2026.